

STUDENT	HASSANI Mohammad Salem	INSTRUCTOR	Asen Grozdanov
COURSE	420-3C2-DW — Intrusion Tests	DATE	March 2026

■ ■ All actions performed in an isolated VirtualBox Host-only network (vboxnet0). No external systems targeted. Educational purposes only.



1. LAB SETUP & NETWORK TOPOLOGY

Role	OS / Platform	IP Address	Notes
Attacker	Kali Linux	192.168.56.108	Primary scanning platform — Nmap 7.98
Target 1	Metasploitable 2	192.168.56.112	Primary analysis target — intentionally vulnerable Linux
Target 2	Windows Host	192.168.56.113	Secondary target
Gateway	VirtualBox	192.168.56.1	vboxnet0 adapter gateway
Host Machine	VirtualBox Host	192.168.56.100	Physical host NIC

2. PHASE 0 — CONNECTIVITY & INITIAL VALIDATION

2.1 · IP Verification & Connectivity Test

```
ip a
# eth1: 192.168.56.108/24 — confirmed on vboxnet0 subnet

ping -c 4 192.168.56.112
4 packets transmitted, 4 received, 0% packet loss
rtt min/avg/max/mdev = 1.076/1.835/2.858/0.655 ms

ping -c 4 192.168.56.113
4 packets transmitted, 4 received, 0% packet loss
```

2.2 · Host Discovery — ICMP Scan

```
sudo nmap -sn -PE -n 192.168.56.0/24 -oN icmp.txt

Nmap scan report for 192.168.56.1 — Host is up (0.0012s latency)
Nmap scan report for 192.168.56.100 — Host is up (0.00024s latency)
Nmap scan report for 192.168.56.108 — Host is up
Nmap scan report for 192.168.56.112 — Host is up (0.00059s latency)
Nmap scan report for 192.168.56.113 — Host is up (0.0014s latency)
# Nmap done: 256 IP addresses (5 hosts up) scanned in 1.88 seconds
```

2.3 · Host Discovery — ARP Scan

```
sudo nmap -sn -PR -n 192.168.56.0/24 -oN arp.txt

# All 5 hosts confirmed via ARP reply — MAC addresses captured:
192.168.56.100 MAC: 08:00:27:D6:E0:F2 (Oracle VirtualBox)
192.168.56.112 MAC: 08:00:27:42:51:79 (Oracle VirtualBox)
192.168.56.113 MAC: 08:00:27:9E:89:BA (Oracle VirtualBox)
# Nmap done: 256 IP addresses (5 hosts up) scanned in 1.85 seconds
```

3. PART 1 — NMAP SCANNING

3.1 · SYN Scan & Service Detection (Target: 192.168.56.112)

```
sudo nmap -sS -sV -T4 -O 192.168.56.112 -oA target1

PORT STATE SERVICE VERSION
21/tcp open  ftp ProFTPD 1.3.5
22/tcp open  ssh OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13
80/tcp open  http Apache httpd 2.4.7
445/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp open  ipp CUPS 1.7
3306/tcp open  mysql MySQL (unauthorized)
8080/tcp open  http Jetty 8.1.7.v20120910

OS: Linux 3.x - 4.x (Debian-based) | Service Info: Hosts: METASPLOITABLE3-UB1404
```

Port	Service	Version	Risk	Notes
21	FTP	ProFTPD 1.3.5	CRITICAL	Known RCE vuln (CVE-2015-3306 — mod_copy); anonymous login pos
22	SSH	OpenSSH 6.6.1p1	Medium	Older version; brute force risk if password auth enabled
80	HTTP	Apache 2.4.7	High	phpMyAdmin exposed; directory listing via NSE
445	SMB	Samba 3.X–4.X	CRITICAL	Anonymous access, writable shares, SMB signing disabled
3306	MySQL	MySQL (unauthorized)	High	Database port exposed to network
8080	HTTP	Jetty 8.1.7	Medium	Additional web service — potential admin interface

3.2 · Full Port Scan (All 65535 ports)

```
sudo nmap -sS -sV -T3 -p- 192.168.56.112 -oA fullscan

# Additional ports found beyond standard scan:
3500/tcp open  http WEBrick httpd 1.3.1 (Ruby 2.3.8)
6697/tcp open  irc UnrealIRCd
# UnrealIRCd is a known backdoor — CVE-2010-2075
# Nmap done: 1 host up — scanned in 116.58 seconds
```

3.3 · UDP Scan (Top 200 ports)

```
sudo nmap -sU -sV --top-ports 200 -T4 192.168.56.112 -oA udp
```

All 200 scanned ports are in ignored states (open|filtered).

Result: No clear SNMP response detected on UDP/161.

3.4 · NSE Default Scripts Scan

```
sudo nmap -sS -sC -sV -T4 192.168.56.112 -oA scripts
```

```
# Key NSE findings:
80/tcp http-ls: /phpMyAdmin/ /chat/ /payroll_app.php
http-title: Index of / [directory listing ENABLED]
445/tcp smb-security-mode: account_used: guest
authentication_level: user
challenge_response: supported
message_signing: disabled (dangerous, but default)
smb-os-discovery: OS: Windows (Samba 4.3.11-Ubuntu)
Computer name: metasploitable3-ub1404
```

3.5 · SMB Enumeration via Nmap NSE

```
sudo nmap -sV -p 139,445 \
--script smb-os-discovery,smb-security-mode,smb-enum-shares,smb-enum-users \
192.168.56.112 -oA smb

# SMB Shares enumerated:
\\192.168.56.112\IPC$ - STYPE_IPC_HIDDEN (hidden IPC share)
\\192.168.56.112\print$ - READ/WRITE Path: C:\tmp
\\192.168.56.112\public - WWW share Path: C:\var\www\html

# Users enumerated:
METASPLOITABLE3-UB1404\chewbacca (RID: 1000) - Normal user account

# Password Policy:
Minimum password length: 5 | Complexity: Disabled
Lockout Threshold: None [CRITICAL - brute force possible]
```

4. PART 2 — ENUMERATION

4.1 · enum4linux — Full Enumeration

```
enum4linux -a -v 192.168.56.112

# Target: 192.168.56.112 RID Range: 500-550,1000-1050
# Known Usernames: administrator, guest, krbtgt, domain admins, root, bin, none
# Shares found: print$, public, IPC$
# Users found: chewbacca (RID 1000), nobody, root
# Password Policy: Length=5, Complexity=Disabled, Lockout=None
# SMB Security Mode:
```

```
account_used: guest | authentication_level: user
message_signing: disabled (dangerous, but default)
```

4.2 · LDAP Enumeration

```
ldapsearch -x -H ldap://192.168.56.112 -b "" -s base "(objectclass=*)"

ldap_sasl_bind(SIMPLE): Can't contact LDAP server (-1)

# Result: Port 389 filtered – LDAP not accessible on this target.
```

4.3 · SNMP Enumeration

```
snmpget -v2c -c public 192.168.56.112 1.3.6.1.2.1.1.1.0

# Timeout: No Response from 192.168.56.112.

snmpwalk -v2c -c public 192.168.56.112 1.3.6

# Timeout: No Response from 192.168.56.112.

# Result: SNMP not accessible – UDP/161 open|filtered.
```

5. PART 3 — EVASION TECHNIQUES

Three evasion techniques were tested to demonstrate how scan timing and packet characteristics can be manipulated to evade IDS/IPS detection while maintaining accuracy of results.

Technique	Command	IDS Evasion Mechanism	Result	Tradeoff
5.1 Slow Scan (-T1)	time sudo nmap -sS -T1 -p 22,80,445 192.168.56.112	Delays between probes below IDS threshold	Completed in 22s; Backdoor traffic 7s normal	~9x slower
5.2 Decoy Scan (-D RND:10)	sudo nmap -sS -D RND:10 192.168.56.112	10 random spoofed source IPs sent with correct probe	Correct probe ports identified	Effective against IP-based IDS
5.3 Fragmentation (-f)	sudo nmap -sS -f 192.168.56.112	Splits TCP packets into 8-byte fragments	Correct ports identified	Some firewalls reassemble

6. FINAL CONCLUSION & SECURITY ASSESSMENT

CRITICAL FINDING	ATTACK VECTOR	RISK
SMB Anonymous Access + Writable Shares (Port 445 — Samba)	Unauthenticated file read/write on print\$ share; User enumeration without credentials	CRITICAL
ProFTPD 1.3.5 — CVE-2015-3306 (Port 21 — FTP)	mod_copy vulnerability allows unauthenticated file copy to arbitrary server paths	CRITICAL
UnrealIRCd Backdoor — CVE-2010-2075 (Port 6697 — IRC)	Pre-installed backdoor allows unauthenticated remote code execution	CRITICAL

Apache Directory Listing + phpMyAdmin (Port 80 — HTTP)	Full directory listing exposes payroll_app.php; phpMyAdmin accessible without auth	HIGH
MySQL Exposed to Network (Port 3306)	Database port accessible from attacker; brute-force or unauthenticated access possible	HIGH
SMB Signing Disabled (Port 445)	Enables SMB relay attacks — NTLM credentials captured and replayed to other hosts	HIGH

Category	Summary
Hosts Discovered	5 active hosts — 2 primary targets (Metasploitable 2, Windows)
Open Ports (T1)	7 key services: FTP(21), SSH(22), HTTP(80), SMB(445), CUPS(631), MySQL(3306), Jetty(8080)
Additional (Full)	WEBrick(3500), UnrealIRCd(6697) — critical backdoor discovered
LDAP / SNMP	Not accessible — UDP/161 and TCP/389 filtered
Evasion Validated	T1/Slow, Decoy(-D RND:10), Fragmentation(-f) — all produced accurate results
Most Critical Vectors	SMB Port 445 (anonymous+writable) · FTP Port 21 (ProFTPD CVE) · IRC Port 6697 (backdoor)
Tools Used	nmap 7.98 · enum4linux · ldapsearch · snmpget/snmpwalk · Metasploitable 2